

Performance Review & Self-Assessment Report

Employee: Chinmay Dhok | **Role:** Sr. Information Security Analyst | **Organization:** OnlineSales.ai (Osmos.ai)

)

Executive Summary

During the review period from November 2025 to August 2026, the Information Security function focused on strengthening cloud security governance, eliminating supply chain vulnerabilities, achieving regulatory and security compliance standards, and optimizing SaaS infrastructure overhead.

Key achievements include the full lifecycle audit and certification for **ISO 27001:2022** (achieving zero major non-conformities) and **SOC 2 Type II**, automated supply-chain risk remediation across **524 GitHub repositories**, complete alignment with major privacy regulations (**GDPR, CCPA, PDPA, DPDPA**), domain authentication via **Gmail BIMl**, and cost optimization of enterprise licensing across Google Workspace and Gemini AI platforms.

Core Metrics Summary

Strategic Focus Area	Primary Metric / Outcome	Organizational Impact
Code Supply Chain	524 Repositories Audited & Remediated	Zero active IOCs/malware; 42 repos patched for Axios vulnerabilities
Certifications & Audits	0 Major Non-Conformities	ISO 27001:2022 re-certified; SOC 2 Type II successfully renewed

Strategic Focus Area	Primary Metric / Outcome	Organizational Impact
Identity & Access	267 GWS Accounts Re-architected	Cost optimized; suspended accounts purged; 56 Gemini licenses right-sized
Enterprise TPRM	100% On-Time Partner Approvals	Unlocked key commercial partnerships with PayPal, Pine Labs, and BharatPe

Section 1: Security Fixes & Infrastructure Governance

GCP Access Management & Network Security

To establish a robust zero-trust security perimeter across Google Cloud Platform (GCP), a comprehensive Tech Spec Review was conducted. Access models were upgraded from broad administrative privileges to granular, role-based access control (RBAC). Integrated secure remote access via **Tailscale**, establishing encrypted, audit-logged connectivity to internal cloud networks while decommissioning insecure legacy VPN points.

GitHub Repository & Code Supply Chain Security

Conducted an enterprise-wide security audit covering **524 code repositories** within the organization's GitHub infrastructure.

- **Supply Chain Audit:** The automated evaluation confirmed **zero active malware or Indicators of Compromise (IOCs)** across all repositories.
- **Dependency Safe-Pinning:** Implemented strict semantic version pinning for critical packages, including `litellm`, eliminating potential exposure to upstream supply chain injection attacks.

- **Vulnerability Remediation:** Identified and remediated critical high-severity vulnerabilities in [Axios](#), upgrading **42 affected repositories** to version `>= 1.8.2`. Detailed tracking is documented in the [GitHub Details](#) audit log.
- **Static Code Analysis Pipeline:** Integrated **CodeAnt** and automated **CodeReview** security dashboards directly into GitHub Actions CI/CD pipelines. This enforcement blocks unsafe pull requests prior to merging. Details can be reviewed in the [CodeAnt Details](#) repository.

Gmail BIMl (Blue Tick) Deployment

Led the end-to-end technical deployment of Brand Indicators for Message Identification (BIMl) for the primary domain ([osmos.ai](#)). Obtained and validated a Verified Mark Certificate (VMC) and aligned DMARC policies (`p=reject`). This established domain-level authentication, displaying the verified blue checkmark in email clients and preventing phishing attacks spoofing the corporate domain.

Secure GCS Bucket Provisioning

Designed and deployed production-grade Google Cloud Storage (GCS) buckets for developer content management systems, specifically establishing `os-developer-cms-stag-bucket` (staging) and `os-developer-cms-prod-bucket` (production). Applied strict compliance configurations:

- Enforced **Uniform Bucket-Level Access (UBLA)** to eliminate individual object ACL drift.
- Enabled **Public Access Prevention (PAP)** to enforce complete private access.

Stability & Monitoring Improvements

Enhanced cloud operational resilience by engineering custom real-time alerting modules:

- **Cloud SQL Monitoring:** Configured memory, CPU, and connection spike detection alerts to prevent database degradation.

- **Hades Monitor:** Implemented continuous service health monitoring for the internal Hades backend architecture, enabling real-time incident notification and reducing Mean Time to Detect (MTTD).

Section 2: Compliance, Certifications, and Policy Audits

ISO 27001:2022 Certification

Successfully led the organization through the **Stage-2 Surveillance Audit** conducted by **INTERCERT** on June 3–4, 2026. The external audit evaluated Information Security Management System (ISMS) controls across technical, physical, and operational domains.

- **Outcome:** Achieved ISO 27001:2022 re-certification with **zero major non-conformities**. Audit completion records and official statements are archived in the [Certifications Reference](#).

SOC 2 Type II Compliance

Managed the continuous compliance monitoring framework and audit lifecycle for the evaluation period spanning March 1, 2025 – February 28, 2026, in partnership with external auditors Accorp Partners. Successfully validated all Trust Services Criteria—Security, Availability, and Confidentiality—yielding an unqualified SOC 2 Type II audit report.

GDPR, CCPA, and PDPA Compliance Audits

Executed global data protection and privacy audits using the Scrut Automation platform. Evaluated cross-border data transfer mechanisms, cookie consent management systems, data subject access request (DSAR) response SLAs, data minimization principles, and retention schedules. The final assessment earned an overall "Satisfactory" rating across GDPR (EU), CCPA (California), and PDPA (Singapore) frameworks.

DPDPA Compliance

Achieved complete operational alignment with India’s Digital Personal Data Protection Act (DPDPA). Successfully earned official Scrut DPDPA compliance badges. Finalized standardized social media marketing opt-in templates, privacy disclaimers, and structured data breach notification workflows.

Scrut Policy Review & Asset Inventory

Modernized the organizational policy framework by conducting a comprehensive review of **54 HR and Information Governance policies**.

- Leveraged LLM-assisted analysis combined with manual oversight to remove obsolete, legacy policy language and harmonize terms across international operating units.
- Updated asset management ledgers to ensure 100% endpoint registration.
- Maintained active tracking through the [Scrut Task Review Tracker](#) and the centralized [Compliance Evidence Tracking](#) repository.

Compliance Framework	Audit Authority	Status / Result	Key Artifact / Focus Area
ISO 27001:2022	INTERCERT	Certified (0 Major NCs)	Stage-2 Audit (June 3–4, 2026)
SOC 2 Type II	Accorp Partners	Report Issued	Period: Mar 1, 2025 – Feb 28, 2026
GDPR / CCPA / PDPA	Scrut Automation	Satisfactory	Global Privacy & DSAR Validation
DPDPA (India)	Scrut / Internal	Fully Compliant	Consent Forms & Badges Finalized
Governance Policies	Internal / Scrut	54 Policies Modernized	LLM Review & Legacy Purge

Section 3: Operational & Enterprise IT Operations

Google Workspace (GWS) License Migration

Led a domain-wide migration and license restructuring across **267 Google Workspace accounts**. The initiative eliminated duplicate licensing tiers, optimized overall SaaS expenditure, and cleaned up stale organizational units.

- **Enterprise Standard:** Provisioned **200 power-user accounts** with enhanced security features (Vault, advanced DLP, Context-Aware Access).
- **Business Starter:** Right-sized **67 operational accounts** requiring basic collaboration tools.
- **Account Sanitization:** Identified and permanently deleted suspended, offboarded, and unassigned licenses, preventing recurring subscription waste. Migration details are tracked in the [Migration Tracker](#).

Gemini License Cost Optimization

Audited the usage patterns of **56 enterprise Google Gemini AI licenses** (comprising 37 Business and 19 Enterprise tiers). Reallocated dormant or underutilized seats directly to active engineering and business teams, ensuring optimal utilization and reducing monthly SaaS cost metrics. Real-time license mapping is available in the [Gemini Allocation](#) sheet.

BCP Testing & Intercompany Documentation

Owned the execution and documentation of the Business Continuity Plan (BCP) and Disaster Recovery (DR) testing lifecycle:

- Conducted simulated operational outage scenarios to validate Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO).
- Reviewed and updated intercompany Data Processing Agreements (DPAs), Service Level Agreements (SLAs), and internal security governance documentation quarterly to ensure cross-entity compliance.

Infrastructure / SaaS Service	Pre-Optimization State	Post-Optimization State	Quantitative Impact
Google Workspace Tiers	Unstructured Licensing	200 Enterprise / 67 Starter	100% account accountability; reduced seat overhead
Suspended GWS Accounts	Unassigned Paid Seats	Zero Stale Active Seats	Recurring license savings
Gemini AI Subscriptions	56 Unmonitored Seats	37 Business / 19 Enterprise	Reallocated to high-impact users; zero idle cost

Section 4: Third-Party Risk & Vendor Assessments

PayPal Background Verification (BGV) Compliance

To satisfy strict enterprise onboarding requirements mandated by **PayPal**, updated internal employee background verification protocols. Conducted an vendor evaluation comparing background check providers (**Quinfy** vs. **Securitas**). Selected and integrated Quinfy, providing a cost-effective, SMB-friendly platform while meeting PayPal's stringent security standard.

Pine Labs InfoSec & DPA Integration

Facilitated the security review and procurement milestone for **Pine Labs**:

- Processed and resolved complex Data Processing Addendum (DPA) technical queries.
- Formatted official Information Security support documentation and updated cloud network architecture topologies.
- Successfully secured technical approval from Pine Labs' enterprise risk committee.

BharatPe TPRM Self-Assessment

Authored technical responses and compiled evidence for **BharatPe's Third-Party Risk Management (TPRM)** audit. Successfully addressed complex questionnaires covering encryption standards, incident response protocols, disaster recovery plans, and network isolation controls. All submitted evidence and formal response matrices are cataloged in the [BharatPe TPRM Sheet](#).